Checklist Pre-Meeting Komet — 14 Aprile 2026

> *Questo documento raccoglie **tutto** ciò che deve essere completato prima del meeting con Komet Italia/Germania del 14 aprile 2026. Aggiorna le checkbox man mano che completi i punti.*

🚀 1. Deploy tecnico (CRITICO — blocca tutto il resto)

Variabili d'ambiente da aggiungere al VPS (`.env` in produzione)

- [x] **`REDIS_PASSWORD`** — Configurata in produzione. Redis in produzione ha `--requirepass` attivo e backend si connette correttamente.
- [ ] **`SECURITY_ALERT_EMAIL`** — Email a cui inviare gli alert di sicurezza (es. tua email personale o aziendale).
- [ ] **`SMTP_HOST`** — Host del provider SMTP (es. `smtp.gmail.com`, `smtp.sendgrid.net`, ecc.)
- [ ] **`SMTP_PORT`** — Porta SMTP (587 per TLS, 465 per SSL)
- [ ] **`SMTP_USER`** — Username SMTP
- [ ] **`SMTP_PASS`** — Password SMTP
- [ ] **`SMTP_FROM`** — Indirizzo mittente per le email di alert (es. `noreply@formicanera.com`)
- [ ] **`SMTP_SECURE`** — `true` se porta 465 (SSL), `false` per 587 (TLS STARTTLS)
- [ ] **`HETZNER_BUCKET`** — Nome del bucket Hetzner Object Storage per i backup
- [ ] **`HETZNER_S3_ENDPOINT`** — Endpoint Hetzner (es. `https://fsn1.your-objectstorage.com`)
- [ ] **`HETZNER_ACCESS_KEY`** — Chiave accesso Hetzner Object Storage
- [ ] **`HETZNER_SECRET_KEY`** — Chiave segreta Hetzner Object Storage

Migrazioni database (eseguire in ordine sul DB di produzione)

- [x] **Migration 046** — `046-audit-log.sql` — crea `system.audit_log` con REVOKE UPDATE/DELETE (applicata in prod il 5 aprile 2026)
- [x] **Migration 047** — `047-roles-modules-mfa.sql` — ruoli espansi, colonne MFA, tabella `mfa_recovery_codes` (applicata in prod il 5 aprile 2026)
- [x] **Migration 048** — `048-retention-policy.sql` — colonna `last_activity_at` su customers (applicata in prod il 5 aprile 2026)

```
# Comando per eseguire le migration via VPS:
ssh -i /tmp/archibald_vps deploy@91.98.136.198 \
  "cd /home/deploy/archibald-app && docker compose exec -T backend node -e \
  \"const { runMigrations } = require('./dist/db/migrate'); \
    const { createPool } = require('./dist/db/pool'); \
    const pool = createPool({ host: process.env.PG_HOST, database:
process.env.PG_DATABASE, \
      user: process.env.PG_USER, password: process.env.PG_PASSWORD, maxConnections:
5 }); \
    runMigrations(pool).then(() => process.exit(0)).catch(e => { console.error(e);
process.exit(1); });\""
```

Infrastruttura backup

- [ ] **Creare bucket Hetzner Object Storage** — Accedere a console.hetzner.com → Object Storage → New Bucket → nome `archibald-backups`, regione `fsn1`
- [ ] **Testare backup manualmente** dopo il deploy:

  ```
  ssh deploy@91.98.136.198 "cd /home/deploy/archibald-app && docker compose --profile backup run --rm backup"
  ```

  Verificare che il file appaia nel bucket.
- [ ] **Configurare cron sul VPS** per backup notturno automatico:

  ```
  # Sul VPS come utente deploy: crontab -e
  # Aggiungere:
  0 2 * * * cd /home/deploy/archibald-app && docker compose --profile backup run --rm backup >> /home/deploy/archibald-app/logs/backup.log 2>&1
  ```

Deploy del branch

- [x] **Merge/push del branch** `feat/compliance-nis2-gdpr` su master (PR #13, mergiata il 5 aprile 2026)
- [x] **CI/CD passa** — GitHub Actions verde al commit `fd9f3421`
- [x] **Deploy su VPS** — deploy automatico completato il 5 aprile 2026
- [x] **Verificare logs backend** post-deploy — tutti e 5 i container healthy, nessun errore di startup

---

📋 2. Documenti contrattuali (da completare con avvocato)

> *Percorso:* `docs/contracts/`

MSA — `MSA-contratto-saas.md`

- [ ] Inserire **P.IVA Formicola Francesco** (tutti i `[PARTITA IVA DA INSERIRE]`)
- [ ] Inserire **ragione sociale e P.IVA Komet Italia S.r.l.**
- [ ] Inserire **ragione sociale e dati Gebr. Brasseler GmbH & Co. KG** (se contraente diretto)
- [ ] Definire **importo canone mensile** (Art. 5 — Corrispettivo)
- [ ] Definire **data decorrenza contratto** e data firma
- [ ] Decidere **foro competente**: Tribunale di Napoli o arbitrato CAM Milano (Art. 13.4)
- [ ] **Far rivedere da un avvocato** — in particolare le clausole di limitazione responsabilità (Art. 9) e le clausole di recesso (Art. 10)
- [ ] **Far firmare** entrambe le parti prima del meeting o al meeting stesso

DPA — `DPA-art28-gdpr.md`

- [ ] Inserire **dati completi Komet Italia** (Titolare del trattamento)
- [ ] Inserire **P.IVA e indirizzo Formicola Francesco** (Responsabile del trattamento)
- [ ] Identificare e inserire il **provider SMTP** nell'Allegato 1 (sub-processor #3 — attualmente `[DA COMPLETARE]`)
- [ ] Verificare se **Komet ha un DPO nominato** — se sì, inserire i dati di contatto
- [ ] Inserire le **date di decorrenza** del DPA

- [ ] **Far rivedere e firmare da entrambe le parti** — il DPA è obbligatorio per legge (GDPR Art. 28)

SLA — `SLA-allegato-sicurezza.md`

- [ ] Confermare con Komet le **finestre di manutenzione programmate** accettabili
- [ ] Definire il **canale di notifica manutenzione** (email? Slack? sistema ticketing?)
- [ ] Inserire **email contatto supporto** per P1/P2/P3
- [ ] Far firmare come allegato al MSA

Informativa Privacy — `informativa-privacy-utenti.md`

- [ ] Inserire **P.IVA e indirizzo completo Komet Italia** (Titolare del trattamento)
- [ ] Inserire **email DPO Komet** (se nominato) o email per esercizio diritti
- [ ] Verificare se Komet ha un **registro trattamenti** in cui includere Archibald
- [ ] **Distribuire agli agenti** prima o contestualmente al deploy — obbligo Art. 13 GDPR

Note legali IP — `note-legali-ip-titolarita.md`

- [ ] Inserire P.IVA Formicola Francesco
- [ ] Decidere se allegare al MSA o usare come documento separato
- [ ] Far rivedere la clausola sviluppi custom (Art. 3) in relazione a eventuali sviluppi futuri richiesti da Komet

---

🔒 3. Completamenti tecnici post-deploy

- [ ] **Identificare e testare il provider SMTP** — scegliere tra: Brevo (ex Sendinblue, gratuito fino a 300 email/giorno), Mailgun, AWS SES, o Gmail con app password. Testare che gli alert arrivino a `SECURITY_ALERT_EMAIL`.
- [ ] **Abilitare MFA** per l'account admin (Francesco) — accedere alla PWA → Profilo → sezione "Sicurezza" → cliccare "Abilita 2FA". Avere Google Authenticator, Authy o 1Password pronto.
- [x] **Verificare Redis password** — backend si connette correttamente a Redis con la password configurata (verificato il 5 aprile 2026).
- [ ] **Primo backup manuale** — eseguire e verificare che il backup arrivi sul bucket Hetzner.
- [ ] **Test login completo** — verificare il flow MFA dalla PWA su iPhone (Safari standalone) e browser desktop.

📊 4. Compliance operativa (per il meeting)

- [ ] **Aggiornare il registro sub-processor** (`docs/compliance/sub-processors.md`) — inserire il provider SMTP scelto con sede e link al DPA del provider.
- [ ] **Completare i campi `[inserire]`** nell' `archibald-security-compliance-overview.md` — P.IVA, data contratto VPS, data integrazione FedEx.
- [ ] **Stampare/preparare PDF** dei documenti per il meeting:
  - `archibald-security-compliance-overview.md` (overview tecnica per Komet)
  - `DPA-art28-gdpr.md` (da firmare)
  - `MSA-contratto-saas.md` (da firmare)
- [ ] **Preparare demo live** della PWA mostrando:
  - Audit log admin (`GET /api/admin/audit-log`)
  - GDPR erase endpoint (mostrare in staging, non produzione)

- AccessManagementPage con ruoli e moduli

⚖️ 5. Questioni legali da risolvere prima della firma

- ☐ **Struttura contrattuale con la Germania**: se il contraente principale è Gebr. Brasseler GmbH (capogruppo tedesca), il MSA potrebbe richiedere clausole di diritto tedesco e/o una traduzione. Consultare un avvocato specializzato in diritto societario europeo.
- ☐ **NIS 2 italiano (D.Lgs. 138/2024)**: verificare se Formicola Francesco rientra nella categoria "soggetti importanti" come fornitore ICT per Komet — se sì, procedura di registrazione ACN entro i termini di legge.
- ☐ **Registro trattamenti GDPR**: verificare se Formicola Francesco deve tenere un registro dei trattamenti come responsabile del trattamento (Art. 30.2 GDPR). Probabilmente sì — redigere o aggiornare il registro.
- ☐ **Assicurazione cyber risk**: valutare se stipulare una polizza cyber risk per coprire la responsabilità contrattuale verso Komet in caso di data breach.

📅 Timeline consigliata

Entro	Azione
7 aprile	Deploy su VPS, migration DB, variabili d'ambiente, test MFA
8 aprile	Test backup Hetzner, cron configurato, SMTP operativo
9 aprile	Invio bozze MSA + DPA a Komet per revisione preliminare
10 aprile	Revisione avvocato clausole MSA/DPA
11-12 aprile	Compilazione campi `[DA INSERIRE]`, distribuzione informativa privacy agli agenti
13 aprile	Stampa documenti, preparazione demo
14 aprile	**MEETING KOMET** 🎯

Documento generato il 2026-04-02. Aggiornare man mano che i punti vengono completati.